

README — KIT DE ENCUESTA CVSS 4.0

Diagnóstico de Madurez en Gestión de Vulnerabilidades • España 2025–2026

Guía de Uso, Estructura y Despliegue del Kit Completo

KIT DE ENCUESTA CVSS 4.0 • ESPAÑA 2025–2026
Versión: 1.0 • Fecha: Abril 2026
Desarrollado por: Consorcio Internacional de Investigación
en Ciberseguridad, Resiliencia Digital y Gestión del Riesgo

CONTENIDO DEL KIT

Archivo	Descripción	Uso principal	Audiencia
a_modelo_encuesta_integral.md	Instrumento completo: 64 preguntas en 11 secciones	Aplicación directa de la encuesta	Encuestados + equipo investigador
b_guia_metodologica.md	Diseño muestral, validez, análisis estadístico, ética	Implementación rigurosa del estudio	Equipo investigador
c_narrativa_explicativa.md	Contexto, propósito y guía de uso de resultados	Comunicación interna y externa	Dirección + investigadores
d_mapeo_normativo.md	Tabla de correspondencia pregunta ↔ norma (ENS/NIS2/DORA/CRA/ISO)	Justificación regulatoria	CISO + Compliance + Auditores
e_plantilla_excel_igroi.md	Especificación Excel para cálculo IGM y ROI	Análisis cuantitativo de datos	Analistas + CISO
f_plantilla_reporte_ejecutivo.md	Estructura completa del deck PPT (28 diapositivas)	Comunicación de resultados	Dirección + Sector
g_readme_kit_encuesta.md	Este archivo: guía de navegación del kit	Punto de entrada	Todos

PROPÓSITO DEL KIT

Este kit de investigación ha sido diseñado para responder una pregunta sencilla con consecuencias complejas:

¿Cómo están gestionando las organizaciones españolas —especialmente el sector público— las vulnerabilidades de ciberseguridad mediante el estándar CVSS 4.0 en 2025–2026?

La respuesta importa porque:

1.
El sector público español fue el objetivo de >200.000 incidentes en 2025 (CCN-CERT), muchos de los cuales explotaron vulnerabilidades conocidas con CVSS ≥ 7.0 que no habían sido remediadas o habían sido mal priorizadas.
2.
CVSS 4.0 ofrece herramientas que reducen en hasta un 76% el volumen de vulnerabilidades a tratar prioritariamente —cuando se aplican las métricas Threat y Environmental. Pero la evidencia global sugiere que estas métricas raramente se calculan.
3.
El entorno regulatorio ha cambiado radicalmente: NIS2 (octubre 2024), DORA (enero 2025), EUVD (abril 2025) y CRA (septiembre 2026) crean un marco que hace de la gestión profesional de vulnerabilidades una obligación legal, no solo una buena práctica.
4.
No hay datos territoriales sistemáticos sobre el estado de adopción de CVSS 4.0 en España, ni sobre las brechas de madurez por CCAA, sector o tamaño organizacional. Este kit existe para generar esos datos.

El sector público español fue el objetivo de >200.000 incidentes en 2025 (CCN-CERT), muchos de los cuales explotaron vulnerabilidades conocidas con CVSS ≥ 7.0 que no habían sido remediadas o habían sido mal priorizadas.

CVSS 4.0 ofrece herramientas que reducen en hasta un 76% el volumen de vulnerabilidades a tratar prioritariamente —cuando se aplican las métricas Threat y Environmental. Pero la evidencia global sugiere que estas métricas raramente se calculan.

El entorno regulatorio ha cambiado radicalmente: NIS2 (octubre 2024), DORA (enero 2025), EUVD (abril 2025) y CRA (septiembre 2026) crean un marco que hace de la gestión profesional de vulnerabilidades una obligación legal, no solo una buena práctica.

No hay datos territoriales sistemáticos sobre el estado de adopción de CVSS 4.0 en España, ni sobre las brechas de madurez por CCAA, sector o tamaño organizacional. Este kit existe para generar esos datos.

MAPA DE USO DEL KIT

Para Investigadores Académicos

PUNTO DE ENTRADA: `b_guia_metodologica.md`

↓
Diseño muestral → Marco de análisis → Instrumento (`a_modelo_encuesta_integral.md`)
↓
Validación expertos + Piloto → Campo principal
↓
Análisis con plantilla (`e_plantilla_excel_igm_roi.md`)
↓
Publicación con mapeo normativo (`d_mapeo_normativo.md`) como marco teórico

Para CISOs y Responsables de Seguridad

PUNTO DE ENTRADA: `c_narrativa_explicativa.md`
(Leer sección 4.2 "Para el CISO")

↓
Autoevaluación con (`a_modelo_encuesta_integral.md`)
(Responder como ejercicio de autodiagnóstico)
↓
Calcular IGM propio con (`e_plantilla_excel_igm_roi.md`)
↓
Comparar con benchmarks sectoriales → Identificar gaps
↓
Comunicar a dirección con (`f_plantilla_reporte_ejecutivo.md`)

Para Equipos de Cumplimiento y Auditoría

PUNTO DE ENTRADA: `d_mapeo_normativo.md`
(Identificar preguntas relevantes para ENS/NIS2/DORA/CRA)

↓
Usar (`a_modelo_encuesta_integral.md`) como checklist de evaluación de terceros
↓
Verificar cobertura normativa contra tabla maestra de mapeo

Para Administraciones Públicas (CCN, INCIBE, CNPIC)

PUNTO DE ENTRADA: Este README

↓
Distribuir (`a_modelo_encuesta_integral.md`) a entidades bajo competencia
↓
Agregar respuestas en (`e_plantilla_excel_igm_roi.md`) – análisis territorial
↓
Generar informe sectorial con (`f_plantilla_reporte_ejecutivo.md`)
↓
Fundamentar programas de apoyo con (`c_narrativa_explicativa.md` §4.3)

INSTRUCCIONES DE DESPLIEGUE

Opción A — Encuesta Online (Recomendada)

Plataformas compatibles:

- LimeSurvey (open source, on-premises — recomendado para sector público por soberanía de datos)

- Qualtrics (comercial, alta funcionalidad de análisis)
- Microsoft Forms (rápido despliegue en entornos Microsoft 365)
- Google Forms (para encuestas rápidas con muestras pequeñas)

Pasos:

1. Crear formulario siguiendo estructura de `a_modelo_encuesta_integral.md`
2. Configurar bifurcaciones condicionales (ver `b_guia_metodologica.md` §3.2)
3. Activar consentimiento RGPD al inicio
4. Configurar exportación a CSV compatible con `e_plantilla_excel_igm_roi.md`
5. Programar recordatorios automáticos (semanas 3 y 6)

Opción B — Entrevista Estructurada

Para organizaciones del sector público (AGE, CCAA, hospitales):

1. Imprimir/compartir `a_modelo_encuesta_integral.md` previo a la entrevista
2. Usar las preguntas abiertas (P3.5, P6.5, P10.5, P10.6) como guión de profundización
3. Registrar respuestas en plantilla Excel directamente durante la entrevista
4. Tiempo estimado: 45–60 minutos + 15 minutos de análisis posterior

Opción C — Autodiagnóstico Organizacional

Para uso interno como ejercicio de madurez:

1. El CISO/RSI responde individualmente el cuestionario completo
2. Opcionalmente, contrastar con 2–3 miembros del equipo de seguridad
3. Calcular IGM con `e_plantilla_excel_igm_roi.md`
4. Usar resultados como input para el plan de mejora anual



MÉTRICAS DE CALIDAD DEL KIT

Dimensión	Indicador	Objetivo
Cobertura normativa	% preguntas mapeadas a ≥ 1 norma	100% (64/64) ✓
Cobertura CVSS 4.0	% grupos de métricas cubiertos	100% (B+T+E+S) ✓
Fiabilidad instrumento	Alpha de Cronbach (piloto)	≥ 0.70 (a verificar)
Validez de contenido	IVC por panel expertos	≥ 0.80 (a verificar)
Tasa de respuesta objetivo	% cuestionarios completados	$\geq 60\%$
Tiempo medio respuesta	Minutos por encuesta	35–50 min
Precisión muestral	Error muestral con N=525	$\pm 4.3\%$ (95% conf.)



CICLO DE VIDA Y VERSIONADO

- v1.0 (Abril 2026) → Versión inicial · Contexto NIS2+DORA+CRA
v1.1 (Octubre 2026) → Actualización post-CRA (septiembre 2026)
v2.0 (Abril 2027) → Réplica anual con datos longitudinales
v2.1 (Enero 2028) → Incorporación CVSS 4.x (si existe actualización FIRST)

Criterios de Actualización

El kit debe revisarse cuando:

- FIRST publique una actualización de CVSS (nueva versión o errata significativa)
- Se produzcan cambios normativos relevantes (transposición NIS2 en España, nuevos reglamentos UE)
- El análisis longitudinal detecte cambios estructurales en el perfil de madurez del sector
- El piloto inicial revele preguntas con baja tasa de respuesta o alta ambigüedad



REFERENCIAS NORMATIVAS Y TÉCNICAS

CVSS (Common Vulnerability Scoring System)

- FIRST CVSS v4.0 Specification Document (noviembre 2023):
<https://www.first.org/cvss/v4.0/specification-document>
- CVSS v4.0 User Guide: <https://www.first.org/cvss/user-guide>
- CVSS v4.0 Consumer Implementation Guide (enero 2026):
<https://www.first.org/cvss/v4.0/implementation-guide>

Marco Normativo Español

- ENS: Real Decreto 311/2022: <https://www.boe.es/eli/es/rd/2022/05/03/311>
- CCN-STIC 817: <https://www.ccn-cert.cni.es/es/guias/guias-series-ccn-stic>
- INCIBE-CERT Vulnerabilidades:
<https://www.incibe.es/incibe-cert/alerta-temprana/vulnerabilidades>

Marco Normativo Europeo

- NIS2 (Directiva 2022/2555): <https://eur-lex.europa.eu/eli/dir/2022/2555/oj>
- DORA (Reglamento 2022/2554): <https://eur-lex.europa.eu/eli/reg/2022/2554/oj>
- CRA (Reglamento 2024/2847): <https://eur-lex.europa.eu/eli/reg/2024/2847/oj>
- EUVD (ENISA): <https://euvd.enisa.europa.eu>

Inteligencia de Amenazas

- CISA KEV: <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>
- EPSS: <https://www.first.org/epss/>
- SSVC: <https://www.cisa.gov/stakeholder-specific-vulnerability-categorization-ssvc>
- ENISA ETL 2025: <https://www.enisa.europa.eu/publications/enisa-threat-landscape-2025>



COLABORACIÓN Y CONTRIBUCIÓN

Este kit es un instrumento vivo que mejora con cada aplicación. Se agradecen:

- Comentarios sobre la claridad de las preguntas (especialmente las de la sección OT/ICS)
- Datos de pilotos para calibrar el tiempo de respuesta y detectar preguntas problemáticas
- Sugerencias de nuevas preguntas alineadas con cambios normativos
- Traducciones a otras lenguas cooficiales (catalán, euskera, gallego) para despliegue en CCAA

LICENCIA Y USO

Este kit se publica bajo licencia **Creative Commons BY-SA 4.0**:

-  Uso libre para fines de investigación académica y no comercial
-  Adaptación y traducción, citando la fuente original
-  Uso por administraciones públicas españolas sin restricción
-  Uso comercial: requiere mención expresa de autoría
-  No se permite el uso en productos comerciales cerrados sin acuerdo expreso

CONTACTO

Para consultas sobre el kit, coordinación de campo o acceso a datos agregados:

Consorcio Internacional de Investigación en Ciberseguridad y Resiliencia Digital

- Coordinación: [nombre del investigador principal]
- Institución: [universidad / organismo investigador]
- Email: [contacto@institucion.es]
- ORCID del IP: [0000-0000-0000-0000]

"El diagnóstico es el primer acto terapéutico."
– Aforismo médico, aplicable.

Kit de Encuesta CVSS 4.0 · España 2025-2026
Versión 1.0 · Abril 2026
Todos los derechos reservados según términos CC BY-SA 4.0
